



MASTG

Purposes of Keys

MASTG-TEST-0016: Testing Random Number Generation

MASTG-TEST-0204: Insecure Random API Usage

MASTG-TEST-0205: Non-random Sources Usage

MASTG-TEST-0208: Insufficient Key Sizes

MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code

MASTG-TEST-0221: Broken Symmetric Encryption Algorithms

MASTG-TEST-0232: Broken Symmetric Encryption Modes

L1

L2

ANDROID

MASWE-0009

TEST



MASTG-TEST-0208: Insufficient Key Sizes

Overview

In this test case, we will look for the use insufficient key sizes in Android apps. To do this, we need to focus on the cryptographic frameworks and libraries that are available in Android and the methods that are used to generate, inspect and manage cryptographic keys.

The Java Cryptography Architecture (JCA) provides foundational classes for key generation which are often used directly when portability or compatibility with older systems is a concern.

- KeyGenerator** : The [KeyGenerator](#) ↗ class is used to generate symmetric keys including AES, DES, ChaCha20 or Blowfish, as well as various HMAC keys. The key size can be specified using the `init(int keysize)` ↗ method.
- KeyPairGenerator** : The [KeyPairGenerator](#) ↗ class is used for generating key pairs for asymmetric encryption (e.g., RSA, EC). The key size can be specified using the `initialize(int keysize)` ↗ method.

For more information you can consult the MASTG section about "[Key Generation](#)".

Steps

- Run a static analysis tool such as [semgrep](#) on the code and look for uses of the cryptographic functions that generate keys.

Observation

The output should contain a list of locations where insufficient key lengths are used.

Evaluation

The test case fails if you can find the use of insufficient key sizes within the source code. For example, a 1024-bit key size is considered insufficient for RSA encryption and a 128-bit key size is considered insufficient for AES encryption considering quantum computing attacks.

Demos

ANDROID MASTG-DEMO-0012: Cryptographic Key Generation With Insufficient Key Length